

Literature Review and Gap Analysis

AI-Driven Cybersecurity Maturity Assessment

Duke Cybersecurity Program

1.0 Introduction

The governance, risk, and compliance (GRC) landscape has grown substantially more complex in recent years, driven by the simultaneous proliferation of regulatory frameworks and a widening gap between compliance obligations and the organizational capacity to meet them continuously and consistently. Manual assessment processes, long the backbone of cybersecurity maturity evaluation, are increasingly inadequate in environments where organizations must maintain compliance posture across multiple overlapping standards at once. This review synthesizes research across five thematic areas, GRC automation, LLM-based policy analysis, hallucination mitigation and explainability, cybersecurity maturity frameworks, and human-in-the-loop design, to situate the proposed tool within existing scholarship, and to identify the gaps it is positioned to close.

2.0 GRC Automation and Multi-Framework Complexity

The administrative challenge of managing compliance across multiple overlapping standards has become a defining feature of the regulatory environment. Research on critical compliance challenges across industries finds that organizations subject to several concurrent regulatory regimes face exponentially greater complexity than those governed by a single standard, as gaps in one framework frequently cascade into non-compliance with another (Mohammed, 2025). This cross-framework burden is now the norm rather than the exception; industry data indicates that nearly 70% of service organizations must demonstrate compliance against at least six frameworks simultaneously (Coalfire, 2023).

Automated GRC tooling has emerged as a necessary response to this complexity. Pinninti (2025) demonstrates in a cloud environment case study that integrating workflow automation with the NIST CSF substantially reduces assessment time and minimizes the inconsistencies introduced by human review. Pillai & Kumar (2024) extend this finding to audit readiness, showing that AI-driven compliance automation enables continuous monitoring capabilities that static, periodic reviews cannot replicate, and that these systems generate audit-ready documentation automatically. Essien et al. (2025) further establish that AI-driven solutions can process the data volumes and complexity that routinely overwhelm human analysts, validating the efficiency case for automated assessment tooling.

Together, this literature establishes that automation is not merely a performance optimization but a prerequisite for maintaining continuous compliance posture in environments governed by multiple overlapping standards. It also highlights the central gap that motivates this project: no existing tool unifies multi-framework assessment, semantic policy analysis, and structured maturity scoring within a single auditable pipeline.

3.0 Large Language Models for Policy Analysis

The application of large language models to cybersecurity tasks has expanded substantially since the mainstream adoption of transformer architectures. A comprehensive survey spanning 223 studies from 2021 to 2025 documents LLM contributions across threat detection, vulnerability assessment, compliance monitoring, and policy interpretation, noting that LLMs have been deployed to semantically interpret access control policies against regulatory requirements, a task directly analogous to the proposed framework mapping pipeline (Jaffal et al., 2025). Cadet et al. (2024) establish that LLM-based tools materially outperform keyword-matching and rule-based systems in identifying compliance gaps within security policy documents, evaluating firewall rules, access controls, and network segmentation policies against regulatory standards with meaningfully higher accuracy.

This finding is significant for two reasons. First, it validates the semantic approach underlying the proposed tool and confirms that an LLM-based pipeline can detect coverage that pattern-based systems systematically miss, including cases where policies satisfy control requirements through alternative phrasing or implementation approaches not anticipated by rule authors. Second, it highlights the fundamental limitation of existing automated compliance tools, most of which continue to rely on pattern matching rather than contextual understanding.

McIntosh et al. (2023) validate the LLM approach from a reliability angle, showing that enforcing structured JSON outputs substantially reduces hallucination risk, the principal concern for deploying LLMs in high-stakes compliance contexts. Collectively, this body of work positions LLM-based assessment as technically feasible, semantically superior to existing approaches, and subject to well-understood reliability risks that can be addressed through deliberate architectural choices.

4.0 Hallucination Mitigation and Explainability

Hallucination, the generation of confident yet factually incorrect outputs, represents the central reliability challenge for LLMs deployed in compliance contexts. An erroneous control assessment could propagate into a materially incorrect gap analysis and result in misallocated remediation resources. The literature identifies two complementary mitigations as most effective: retrieval-augmented generation (RAG) and structured output constraints.

A systematic review of 25 LLMs across over 300 studies establishes that RAG architectures consistently outperform standard LLM inference on knowledge-intensive tasks by grounding model outputs in retrieved, authoritative context rather than relying on training data alone (Zhang et al., 2025). In applied cybersecurity settings, RAG-based systems have achieved strong performance benchmarks: the LOCALINTEL threat intelligence system reached a RAGAS score of 0.9535, while the LLMCloudHunter framework achieved 92% precision and 98% recall in cloud threat detection (Jaffal et al., 2025). Applied to the proposed pipeline, RAG ensures that each maturity assessment is grounded in the organization's actual submitted policy text, constraining model reasoning to evidence that human reviewers can directly verify.

Beyond hallucination, the literature identifies explainability as a first-class requirement for AI systems deployed in compliance contexts. Research synthesizing XAI techniques confirms that interpretable models enable faster and more confident responses from human analysts, and that transparent decision-making is especially critical in regulated industries where accountability must be demonstrable to auditors and legal stakeholders (Mohale & Obagbuwa, 2025; Oriaro & Mishra, 2025).

The EU AI Act's emerging mandates further reinforce this direction, requiring transparency, bias detection, and documented human oversight for AI systems operating in consequential decision domains (Jain, 2025). The proposed architecture addresses this requirement through structured outputs that pair each maturity score with explicit evidence references and control-level justifications, enabling analysts to inspect and override the system's reasoning at a granular level.

5.0 Cybersecurity Maturity Frameworks

The theoretical foundation for maturity-based assessment is well established. The Cybersecurity Maturity Model Certification (CMMC) and the NIST capability maturity model formalize a five-level taxonomy, from initial, ad hoc implementation through optimized, continuously improved controls, that moves beyond binary compliance indicators to reflect the operational effectiveness of security programs (NIST, 2024). Research confirms that organizations using structured maturity frameworks allocate security resources more efficiently, demonstrate stronger audit readiness, and experience fewer compliance violations than those relying on informal self-assessment (Al-Matouq et al., 2020).

The NIST SP 800-53 control family structure, spanning Access Control, Incident Response, Risk Assessment, Configuration Management, and related domains, provides the granular scoring substrate for the proposed weighted maturity model, where control-family scores are aggregated and weighted by system impact level to produce an overall posture score on a 1-5 scale. This approach preserves the interpretability of domain-level subscores while enabling organizations to track their aggregate posture relative to each assessed framework and benchmark maturity trajectory over time as remediation activities are implemented.

6.0 Human-in-the-loop as Architectural Imperative

A recurring finding across the AI compliance literature is that full automation of judgment-sensitive assessment tasks introduces unacceptable risk. Edgar et al. (2025) confirm that AI systems using behavioral analysis can generate consistent, defensible compliance assessments, but frame this as a capability that reduces, rather than eliminates, the need for human validation. This framing reflects a broader convergence in the compliance industry: leading practitioners now describe AI's role as collapsing manual effort in high-volume, document-heavy workflows while embedding human oversight at points of genuine ambiguity, redirecting analyst attention toward interpretation and ethical judgment rather than replacing it (FinTech Global, 2025).

Zhang et al. (2022) provide one of the most architecturally concrete treatments of this principle in the cybersecurity literature. Surveying AI applications across user authentication, network situation awareness, dangerous behavior monitoring, and abnormal traffic identification, they conclude that AI

cannot reliably replace human judgment across all event types, and propose a Human-in-the-Loop Cyber Security Model (HLCSM) as a direct response to this limitation.

The model's core mechanism, a Confidence Level Module that routes low-confidence automated outputs to mandatory human review while allowing high-confidence outputs to proceed, directly mirrors the confidence thresholding approach adopted in the proposed tool's framework mapping pipeline. Zhang et al. also demonstrate that this structure improves reliability and interpretability compared to fully automated baselines, precisely because human analysts retain override authority and their decisions are used to calibrate the system over time. Their framing is unambiguous: AI is to assist security specialists, not replace them, and the architecture must enforce this relationship structurally rather than relying on downstream review as an afterthought.

This position has regulatory support. The EU AI Act mandates human oversight, explainability, and audit trails for high-risk AI systems, and research consistently frames human annotation and review as essential not only for model accuracy but for satisfying emerging regulatory standards (Humans in the Loop, 2025). Research on XAI in cybersecurity further reinforces this: explainability techniques improve analyst trust and decision confidence, but the literature is consistent in positioning these as supports for human judgment rather than substitutes for it (Oriaro & Mishra, 2025). Research on risk-based HITL frameworks further recommends calibrating oversight intensity to the consequences of error, with consequential compliance decisions warranting mandatory human review and full interaction logging (Ammon, 2025).

The proposed tool treats the human review checkpoint as a first-class architectural component throughout the pipeline. Low-confidence framework mappings are systematically surfaced for mandatory analyst evaluation. All review interactions are logged to support auditability and downstream model improvement. No assessment output is finalized without explicit analyst sign-off. This design reflects the literature's consensus position: that in high-stakes, regulated domains, responsible deployment of AI requires human oversight to be embedded by design, not applied after the fact.

7.0 Gap Analysis

The literature collectively surfaces three gaps that warrant further investigation. First, no published tool simultaneously evaluates organizational security artifacts against a broad suite of major frameworks, including NIST CSF, NIST SP 800-53, ISO 27001, CIS CSC, CMMC, HIPAA, PCI-DSS, CSA-CCM, and the FTC Safeguards Rule, within a single unified maturity assessment interface. Existing tools either target a single framework or require separate, fragmented assessments per standard, precisely the cross-framework burden that Mohammed (2025) identifies as the defining compliance challenge for multi-regulated organizations. Whether a unified interface can be made practically tractable, in terms of framework coverage, scoring consistency, and output quality, remains an open question.

Second, current compliance automation tools predominantly rely on rule-based or keyword matching rather than semantic understanding, limiting their ability to recognize when organizational policies satisfy control requirements through alternative phrasing or non-standard implementation approaches. LLM-based semantic matching offers a plausible path forward here (Cadet et al., 2024; Zhang et al.,

2025), but empirical validation of this approach in the specific context of multi-framework maturity scoring against real organizational policy documents has not yet been established.

Third, no open-source tool currently implements control-family-weighted maturity scoring across multiple frameworks using a RAG-grounded LLM evaluation pipeline with structured, auditable outputs and an embedded human review workflow (Edgar et al., 2025). Exploring whether such a pipeline can produce assessments that are both reliable and defensible enough for practical use represents a meaningful area of inquiry, and one that applied research in this space is well positioned to address.

8.0 Closing Remarks

The literature surveyed here converges on a consistent set of conclusions that together define both the opportunity and the obligation for the proposed tool. Automated GRC workflows are no longer an optimization, they are a structural necessity for organizations operating under multi-framework compliance obligations that exceed the capacity of manual assessment processes. Large language models have matured to the point where semantic policy analysis is not only feasible but demonstrably superior to the pattern-matching approaches that dominate existing tooling.

RAG architectures have resolved the most acute reliability concerns by grounding model reasoning in submitted evidence rather than training assumptions. And the literature on explainability and human-in-the-loop design has produced clear architectural guidance: confidence-gated human review, traceable justifications, and mandatory analyst sign-off are not optional safeguards, but prerequisites for responsible deployment in regulated, consequential domains.

What the literature has not yet produced is a tool that assembles these capabilities into a unified, multi-framework maturity assessment pipeline with auditable outputs and embedded human oversight. That absence is the direct motivation for this project. The proposed tool is not a theoretical contribution to any of the individual research streams reviewed here, it is an applied synthesis of their combined findings, implemented as a working proof of concept designed for practical deployment in organizational cybersecurity programs. Each architectural decision documented in this proposal, from the RAG-grounded ingestion pipeline to the confidence thresholding mechanism to the analyst review interface, traces directly to findings in this literature.

A.0 Appendix

A.1 References

Al-Matouq, H., Mahmood, S., Alshayeb, M., & Niazi, M. (2020). A maturity model for secure software design: A multivocal study. *IEEE Access*, 8, 215758–215776.

<https://doi.org/10.1109/ACCESS.2020.3040220>

Ammon, K. (2025). The role of human-in-the-loop in AI-driven data management. *TDWI*.

<https://tdwi.org/articles/2025/09/03/adv-all-role-of-human-in-the-loop-in-ai-data-management.aspx>

Cadet, E., Etim, E. D., Essien, I. A., Erigha, E. D., Babatunde, L. A., Ajayi, J. O., & Obuse, E. (2024). Large language models for cybersecurity policy compliance and risk mitigation. *International Journal of Scientific Research in Humanities and Social Sciences*. <https://doi.org/10.32628/IJSRSSH242560>

Coalfire. (2023). The state of cybersecurity compliance in 2023: Part 1. *Coalfire Blog*.

<https://coalfire.com/the-coalfire-blog/the-state-of-cybersecurity-compliance-in-2023>

Edgar, T., Lowell, E., Winslow, C., & Harlan, T. (2025). Automated risk scoring models for security compliance using AI and behavioral analysis. ResearchGate.

<https://www.researchgate.net/publication/398660985>

Essien, I. A., Cadet, E., Ajayi, J. O., Erigha, E. D., & Obuse, E. (2025). AI-driven continuous compliance and threat intelligence model for adaptive GRC in complex digital ecosystems. *Computer Science & IT Research Journal*, 6(7). <https://www.researchgate.net/publication/394998384>

FinTech Global. (2025). How are AI agents transforming the future of compliance?

<https://fintech.global/2025/12/16/how-are-ai-agents-transforming-the-future-of-compliance/>

Humans in the Loop. (2025). How human-in-the-loop powers responsible AI through data annotation.

<https://humansintheloop.org/how-humans-in-the-loop-powers-responsible-ai-through-data-annotation/>

Jaffal, N. O., Alkhanafseh, M., & Mohaisen, D. (2025). Large language models in cybersecurity: A survey of applications, vulnerabilities, and defense techniques. *AI*, 6(9), 216.

<https://doi.org/10.3390/ai6090216>

Jain, A. (2025). AI and privacy 2024 to 2025: Embracing the future of global legal developments. *Cloud Security Alliance*.

<https://cloudsecurityalliance.org/blog/2025/04/22/ai-and-privacy-2024-to-2025-embracing-the-future-of-global-legal-developments>

McIntosh, T., Liu, T., Susnjak, T., Alavizadeh, H., Ng, A., Nowrozy, R., & Watters, P. (2023). Harnessing GPT-4 for generation of cybersecurity GRC policies: A focus on ransomware attack mitigation. ResearchGate.

https://www.researchgate.net/publication/373072662_Harnessing_GPT-4_for_Generation_of_Cybersecurity_GRC_Policies_A_Focus_on_Ransomware_Attack_Mitigation

- Mohale, V. Z., & Obagbuwa, I. C. (2025). A systematic review on the integration of explainable artificial intelligence in intrusion detection systems to enhancing transparency and interpretability in cybersecurity. *Frontiers in Artificial Intelligence*, 8. <https://doi.org/10.3389/frai.2025.1526221>
- Mohammed, A. R. (2025). Critical compliance challenges across industries and the role of automation. ResearchGate. <https://www.researchgate.net/publication/394471615>
- NIST. (2024). *Cybersecurity Framework 2.0*. National Institute of Standards and Technology. <https://www.nist.gov/cyberframework>
- Oriaro, S., & Mishra, S. (2025). Improving cybersecurity through explainable artificial intelligence: A systematic literature review. *Issues in Information Systems*, 26(3), 387–400. https://doi.org/10.48009/3_iis_2025_2025_131
- Pillai, A. V., & Kumar, K. (2024). The impact of AI-based compliance automation on regulatory audit readiness. ResearchGate. <https://www.researchgate.net/publication/397454385>
- Pinninti, V. P. (2025). Automating governance, risk, and compliance (GRC) in cloud computing: A case study on ServiceNow and NIST framework integration. https://www.researchgate.net/publication/397029207_Automating_Governance_Risk_and_Compliance_GRC_in_Cloud_Computing_A_Case_Study_on_ServiceNow_and_NIST_Framework_Integration
- Zhang, J., Bu, H., Wen, H., Liu, Y., Fei, H., Xi, R., Li, L., Yang, Y., Zhu, H., & Meng, D. (2025). When LLMs meet cybersecurity: A systematic literature review. *Cybersecurity*, Springer Nature. <https://link.springer.com/article/10.1186/s42400-025-00361-w>
- Zhang, Z., Ning, H., Shi, F., Farha, F., Xu, Y., Xu, J., Zhang, F., & Choo, K.-K. R. (2022). Artificial intelligence in cyber security: research advances, challenges, and opportunities. *Artificial Intelligence Review*, 55(2), 1029–1053. <https://doi.org/10.1007/s10462-021-09976-0>